

개 선 · 통 보

제 목 백업 데이터 복구훈련 실시 및 사후관리 미흡

관 계 부 서 ☆☆☆☆☆처

내 용

백업(Back-up)이란 정보시스템의 장애나, 화재와 같은 재해로 인해 저장해 둔 정보가 소실되거나 손상될 경우에 대비하여 일정한 시간 차이를 두고 데이터를 복사하여 별도의 매체(디스크 혹은 테이프 등)에 예비로 저장해두는 행위를 말하며 이를 통해 예기치 못한 사고로 시스템이나 파일에 피해를 입더라도 최근에 백업한 시점의 내용으로 복구할 수 있다.

최근 공공기관을 포함한 일반기업에서의 업무는 대부분 정보시스템을 통해 처리되고 있으며, 그 결과물이 정보시스템 내에서 축적되는바, 백업의 중요성은 증대되고 있으며, 공사는 「데이터 백업관리 절차서」에 의거 백업업무 관련 역할과 책임, 백업 데이터 기록 관리 및 백업 매체 보관방법, 백업 주기 및 보관기간 등에 대한 원칙을 마련하여 운영하고 있다.

공사의 정보시스템 백업은 1시간전 데이터의 복구를 목표로 3단계로 이루어지는데, 우선 중요 정보시스템의 데이터는 본사 IT데이터센터 내의 스토리지에 1

차로 백업되며, 1차로 백업된 데이터와 여타 시스템의 데이터를 포함한 전체 데이터가 2차로 IT데이터센터 내의 테이프에 백업되며, 끝으로 본사의 데이터 소실사태 등에 대비하여 주요 정보시스템의 데이터는 원격지인 DR센터(Disaster Recovery)에 설치된 스토리지에 3차로 백업되고 있다.

공사 백업 업무 운영 체계

구분	백업위치	대상시스템	백업매체	복구수준
1차 백업	본사(IT데이터센터)	중요시스템*	스토리지	1시간 전 데이터
2차 백업	본사(IT데이터센터)	전체시스템	테이프	1시간 전 데이터
3차 백업	 DR센터**	중요시스템*	스토리지	1시간 전 데이터

* 중요시스템 : ERP, 페트로넷, 오피넷, 페드시스, 지식관리시스템 등 공사 핵심정보시스템

** DR(Disaster Recovery)센터 : 지사에 위치한 재난대비용 원격지 백업센터

한편, 백업의 유효성과 백업된 데이터의 무결성¹⁾을 검증하기 위하여 모의훈련을 실시하는 것이 바람직하며²⁾, 공사 「보안업무처리규정」 제116조(재난방지)에 따르면 정보시스템 운용 주관부서는 인위적 또는 자연적인 원인에 의한 정보통신망의 장애발생에 대비하여 백업관리, 복구 등 종합적 재난방지대책을 수립·시행하여야 하며, 정기적으로 시험·검토하도록 규정하고 있다.

관련하여 ☆☆☆☆☆처에서는 매년 자체판단을 거쳐 주요 정보시스템을 선정하여 서버의 데이터베이스 파일 손상 등 특정 장애상황을 가정한 시나리오에 의거 실제 백업 데이터를 복구하여 이상 여부를 검증하거나 복구 소요시간을 확인하기 위한 백업복구훈련을 실시하고 있었다.

1) 무결성(Integrity)이란 데이터정보가 권한이 없는 사용자(조직)에 의해 변경되지 않는 것을 말함. 즉 해당 데이터 정보가 인가된 사람에 의해 접근 또는 변경된다는 상태임

2) 한국정보통신기술협회의 「정보시스템 백업 지침」 6.5 모의훈련에 따르면 백업시스템이 구축되어 있는 경우 적절한 시스템을 선택하여 주기적으로 백업에 대한 유효성 및 무결성을 검증하기 위한 모의훈련을 실시하도록 권장하고 있음

2014년~2017.10월 백업복구훈련 실시 현황

년도	구분	훈련기간	대상시스템
2014년	2014년 백업/복구훈련	11.7~11.8 11.14~11.15 11.15~11.17 11.28~11.29	- ERP, 석유정보, 알뜰주유소, 웹메일 등 ※ 신사옥 IT센터 이전사업과 연계하여 실시 (☐☐DR센터 백업데이터 활용)
2015년	2015년 백업/복구훈련	5월~11월	- SAP ERP, 전사포탈, 그룹웨어 등 ※ 복구훈련을 실시하였으나, 그 결과물을 기록물 대장에 등록하지 않음
2016년	1차 백업/복구훈련	4.14~4.15	ERP 운영, ERP QA
	2차 백업/복구훈련	10.27	ERP 운영DB, ERP KTS
	3차 백업/복구훈련	10.29	그룹웨어
2017년	1차 백업/복구훈련	6.15~6.16	ERP 운영DB, ERP KQS
	2차 백업/복구훈련	10.17	ERP KTS(ktasdc)

다만, 감사기간 중 ☆☆☆☆☆처의 백업복구훈련 실시 사항에 대한 점검결과, 다음과 같은 취약점이 발견되어 개선이 필요한 것으로 검토되었다.

오피넷 등 대외 서비스 시스템에 대한 백업복구훈련 미실시

실제 장애 발생 시 백업된 데이터를 활용한 복구절차는 백업절차와 마찬가지로 백업 대상 및 방법별로 다양할 수 있어, 시스템별 복구전략을 사전에 마련할 경우 복구시간을 최소화하는데 도움이 될 수 있다. 따라서 백업담당부서는 주요 정보시스템을 대상으로 주기적으로 모의훈련을 실시하고, 이러한 모의훈련을 통해 시스템별 복구전략을 도출하여야 하는데, ☆☆☆☆☆처에서 실시한 백업복구훈련별 대상시스템을 확인한 결과, 내부적으로 중요 시스템으로 분류 중인 석유정보시스템(페트로넷, 페드시스, 오피넷)에 대해서는 2014년 사옥 이전에 따른 사항을 제외하고는 백업복구훈련을 실시하지 않고 있었다. 그룹웨어 및 ERP 등

내부 시스템은 장애가 발생하여도 공사 직원(또는 정부기관 및 협력업체)에 한하여 불편을 초래하나, 대외 시스템 중단 시 일반 국민과 시스템을 활용하는 이해관계자의 업무에 지장을 주어, 공사 이미지 저하 등 부정적 효과가 보다 클 수 있다.

백업복구훈련 결과 기록관리 부실

한국정보통신기술협회의 「정보시스템 백업 지침³⁾」과 공사 「자체 사이버안전 및 위기대응 행동매뉴얼」 별첨1 [정보시스템 백업 및 복구 운영계획⁴⁾]에 따르면, 백업복구훈련 시 그 결과는 잘 정리되어 보고되어야 하며, 데이터 복구 시점 및 서비스 정상가동 유무 확인 등 복구훈련시간의 적정 여부를 확인하고, 세부사항 등을 기록·평가하도록 기술하고 있다. 그런데, ☆☆☆☆☆처에서 실시한 백업복구훈련 결과 보고 문서를 점검한 결과, 2015년에는 훈련 실시 이후 그 결과물을 기록물 대장에 등록하지 않아 세부내용을 확인할 수 없는 상황이며, 2016년 2차~3차 및 2017년 1차~2차 훈련의 경우 결과 보고서에 시스템 중단 시점과 복구 시점 등을 증빙할 수 있는 자료가 포함되지⁵⁾ 않아, 부서장 등 상위자가 실제 훈련이 정상적으로 실시되었는지 여부를 판단하기 곤란하였다.

백업복구훈련은 유사시를 대비하기 위하여 구축된 백업시스템이 올바르게 운영되고 있는지, 기존의 백업된 데이터가 오염되지 않고 적정하게 관리되고 있는

3) 한국정보통신기술협회의 「정보시스템 백업 지침」 6.5 모의훈련에 따르면 시스템 담당자는 모의훈련을 통해 시스템별 평균 복구시간(MTTR(Mean Time To Recovery))을 예측할 수 있어야 하고, 복구훈련 후 훈련결과는 잘 정리되어 보고되고, 개선 사항은 훈련 중 또는 별도 변경절차에 의거 수정·반영하도록 기술하고 있음

4) 「정보시스템 백업 및 복구 운영계획」 3.백업/복구테스트 절차에 따르면 백업복구훈련 시 백업한 데이터에 대해 복구를 수행하여 복구시간이 적정한지 여부를 확인(데이터 복구범위 및 시점 확정, 서비스 정상가동 유무 확인 등)하고, 대상 서비스 및 손실 데이터량 등 세부사항을 기록 평가하여 개선책을 마련하도록 기술하고 있음

5) 2014년 및 2016년 1차 백업복구훈련 결과 보고서에는 복구 시점을 확인할 수 있는 증빙자료(화면캡처)를 첨부하여 보고함

지, 데이터를 복구할 경우 그 시간이 적정한 지 등을 확인하고 검증하기 위한 중요한 절차인바, 체계적인 원칙이나 목표 등에 따라 실시되지 않을 경우 실제 정보시스템에 화재 등의 장애 발생 시 백업체계가 정상적으로 작동되지 않아 장시간 정보시스템이 중단되는 등 업무상 피해가 막대할 수 있는바, 철저한 관리가 요구된다.

조치할 사항

☆☆☆☆☆처장은 백업의 유효성과 백업된 데이터의 무결성을 검증하기 위한 백업복구훈련을 체계적으로 실시하기 위해 훈련 실시 주기, 대상 시스템, 절차 및 보고방법 등 백업복구훈련 관련 주요 사항을 「데이터 백업관리 절차서」에 반영하여 운영하시기 바랍니다. (개선)

또한, 백업복구훈련 실시 후 데이터 복구 시점 및 서비스 정상가동 유무 확인 등 시나리오에 따른 훈련결과 세부사항에 대한 기록관리를 철저히 해주시길 바랍니다. (통보-회보불요)